

Security Scan Exemption Letter

Solution: EcoSystem Compliance API v1

Listing: EcoSystem AEC + Regulatory

Date: June 26, 2026

This solution is classified as **APIA (API-only)** — it does not contain a Salesforce Managed Package, Lightning Components, Apex code, or any deployable Salesforce metadata. The solution is an external SaaS platform that integrates with Salesforce exclusively via REST API calls.

Why a Source Code Scanner is Not Applicable:

- No Salesforce Managed Package — the solution is not packaged or deployed via SFDX
- No Apex, Lightning Web Components, Visualforce, or any Salesforce Platform code
- The backend (Python/FastAPI) runs entirely outside Salesforce on Render.com
- Communication with Salesforce is strictly via REST API (OAuth 2.0)

Security measures already in place:

- All API communications use HTTPS/TLS 1.2+
- Authentication via OAuth 2.0 with short-lived JWT tokens
- API Keys for MCP server access
- RBAC per tenant with audit trail
- PII masking on all agent outputs
- Secrets managed via HashiCorp Vault
- Circuit breaker pattern to prevent abuse
- Rate limiting per tenant

A Dynamic Application Security Testing (DAST) scan has been performed on the public API endpoints using OWASP ZAP. The scan covered authentication, injection, XSS, and data exposure vectors. All critical and high-severity findings have been resolved. The DAST report is attached separately.